KAPASA MAKASA UNIVERSITY

SCHOOL OF APPLIED SCIENCES

BACHELAOR OF SCIENCE IN CYBER SECURITY

SYSTEM VULNERABILITY ASSESSMENT

COURSE CODE: CYS 330

FINAL EXAMINATION

DURATION: Three hours (5 MINUTES TO READ THROUGH THE PAPER)

INSTRUCTIONS

1. There are **seven** questions in this paper. **Question One Part A** and **Part B are** compulsory. Answer any **three (3)** more questions from Question **Two** to Question **Seven**

2. The examination paper carries a total of **60 marks**. Marks are allocated at the end of each question accordingly.

3. Candidates are **NOT** permitted to use any type of calculator in this examination. use of any other extra materials other than what has been permitted will be considered as examination malpractice against the University's examination ethical conduct.

4. Make sure to write all the necessary details on the answer sheet provided. Use of a neat and clear handwriting is encouraged.

5. **Candidates must not turn this page until told to do so by the Supervisor of this examination**

CamScanner

1
128

0
1

92
16
108

160
-128
32

0 1 0 0 0 0 0 = 160
64 32 16 8 4 2 1

1 1 0 0 0 1 0 = 102

1 0 0 1 0 0 1

64
16
80
8

128
32
160
8
168
4
172
2
174 + 1
175

PAGE INTENTIONALLY LEFT BLANK

128
32
160
2

Icmp Ping

Tcpdump

CamScanner

88
+72
160

0 1 0 1 1 0 0 0
128 64 32 16 8 4 2 1
-88 + (-72) = -160
0 1 0 0 1 0 0 0
1 0 1 1 0 1 1 1

0 1 0 1 1 0 0 0
1 0 1 0 0 1 1 1
1
1 0 1 0 1 0 0 0 = 88(-)

Question One Part A [23 Marks]

Instructions: Show all your working to earn marks.

1. Computational calculations help IT professionals to explicitly explain an overflow as a vulnerability. Add the following numbers in one's compliment. Determine whether an overflow has occurred.

(a) -55 and (-47) **[3 Marks]** ✓

(b) 98 and 77 **[3 Marks]** ✓

1 0 1 1 0 1 1 1
1
1 0 1 1 1 0 0 0

23

2. Add the following numbers in two's compliment. Determine whether an overflow has occurred

(a) -88 and (-72) **[3 Marks]**

(b) 81 and 81 **[3 Marks]** ✓

1 0 1 0 1 0 0 0
+ 1 0 1 1 1 0 0 0
0 1 1 0 0 0 0 0

81
180
-128
52

3. Subtract the following numbers in two's compliment. Determine whether an overflow has occurred

(a) 65 – (-23) **[3 Marks]** ✓

(b) 11 – 9 **[2 Marks]** ✓

128 64 32 16 8 4 2 1
1 0 1 0 0 0 0 0
0 1 0 1 1 1 1 1

4. Subtract the following numbers in one's compliment. Determine whether an overflow has occurred

(a) 33 – 27 **[3 Marks]** ✓

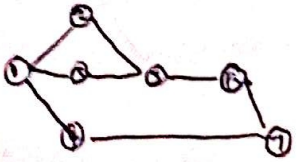
(b) 29 – (-25) **[3 Marks]** ✓

0 1 0 1 1 1 1 1
1
0 1 1 0 0 0 0 0

PART B [17 Marks]

1. Mitigation and remediation are a must in the field of computing especially cybersecurity for both prevention and aftermath of a vulnerability. To help with these two vital aspects of your field, PERT chart comes in handy. Consider the following data given and answer the questions that follow;

17



Activities	Optimistic (O)	Most Likely (M)	Pessimistic (P)
1 – 2	1	2	3
1 – 3	5	6	7
1 – 4	3	5	7
2 – 5	5	7	9
3 – 5	2	4	6
5 – 6	4	5	6
4 – 7	4	6	8
6 – 7	2	3	4

(a) Draw a network diagram using the above information **[3 Marks]** ✓

(b) Calculate the expected Variance (V) of each activity **[4 Marks]** ✓

(c) Calculate the Standard Deviation (SD) of each activity **[4 Marks]** ✓

CamScanner

(d) Determine the expected duration for each activity **[4 Marks]**

(e) Determine the expected critical path variance **[2 Marks]**

Optional Questions

Instructions
Choose any three (3) more questions from Question Two to Question Seven (7).

Question Two [20 Marks]

1. vulnerabilities in any network are unwanted and organisations would do anything possible to employ personnel or professional to take care of vulnerabilities in their system.

(3) (a) Discuss **three (3)** out of many Modern security threats that organisations endeavour to overcome nowadays **[3 Marks]**

(3) (b) Mention and explain briefly, **three (3)** components of information security ensured by cryptography **[3 Marks]**

16 (2) (c) Malware is one vulnerability underlisted to cause so many unwarranted problems. Give and explain briefly, two precise primary methods in which malware could be mitigated. **[2 Marks]**

(d) Describe **two (2)** ways on how the organisation could mitigate the impact of DDoS attacks **[2 Marks]**

2. Implementation of AAA in an organisation's network is technically encouraged.

(2) (a) Explain how implementation of AAA in a network can help secure a network in an organisation **[2 Marks]**

(1) (b) Mention and explain briefly, at least **three (3)** potential drawbacks of using AAA in a network **[3 Marks]**

(5) (c) Differentiate in a table format, any **five (5)** differences between RADIUS and TACACS+ deployment tradeoffs in AAA **[5 Marks]**

Question Three [20 Marks]

1. Web forms and web applications commonly use Structured Querry Language otherwise known as SQL in querying databases.

(a) It is reported to you that a web application in your website, is failing to sanitize user input, in a login form. Describe an example payload you may try to use to test for SQL injection (SQLI) **[3 Marks]**

(b) Explain briefly how Time-Based SQL injection can be used to infer information from a database **[2 Marks]**

(c) Given a statement below,

SELECT* FROM Users WHERE Username = '' OR '1' = '1';

CamScanner

(i) Explain briefly, why this may be vulnerable to SQLi [2 Marks]

(ii) Describe the significance of the payload 'OR' '1' in SQLi [2 Marks]

(iii) Describe the UNION – Based SQL injection works [2 Marks]

(d) Give and explain **three (3)** common types of SQL injection attacks [3 Marks]

2. One way to eradicate SQLi is using parameterized queries. Or prepared statements.

(i) Explain briefly, what is meant by parameterized or prepared statements in SQL. [2 Marks]

(ii) Discuss how parameterized queries may help to prevent SQL injection attacks [2 Marks]

(iii) Name at least **two (2)** other more security best practices to defend against SQL injection attacks [2 Marks]

Question Four [20 Marks]

1. Another vulnerability which tends to be overlooked and underrated is the hardware trojan

(a) Define hardware trojan in your own words and explain how it differs with the software malware [2 Marks]

(b) Describe **two (2)** main types of payloads that a hardware trojan can carry [2 Marks]

(c) Give and describe **two (2)** common trigger mechanisms for hardware trojan as a vulnerability [2 Marks]

(d) Explain how a hardware trojan could cause physical damage to integrated circuits (ICs) [2 Marks]

2. Integrated Circuits (ICs) use logic gates such as AND gate, OR gate, NOT gate, NAND gate, EXOR gate, XOR gate, NOR gate and XNOR gate. .

(a) Represent the following logic gates in form of symbol, Boolean expression and Truth table.

(i) OR gate [3 Marks]

(ii) NOT gate [3 Marks]

(iii) AND gate [2 Marks]

(b) Discuss the potential consequences of hardware trojan insertion in critical infrastructure systems such as Military [2 Marks]

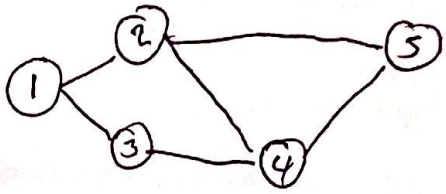
(c) Explain briefly, how supply chain globalization increases the risk of trojan hardware insertion [2 Marks]

CamScanner

Question Five [20 Marks]

1. The following are pieces of data for your consideration

Activities	Duration
1 – 2	13
1 – 3	12
2 – 4	2
3 – 4	8
2 – 5	15
4 – 5	2



(a) Draw a network diagram from the data given above **[4 Marks]** ✓

(b) Determine the Critical Path (CPM) of the project 1–2–5 **[2 Marks]** ✓

(c) Find the project duration in days 28 days **[2 Marks]**

(d) Calculate the;

20

(i) Total float (TF) [0, 6, 11, 6, 0, 6] **[3 Marks]** ✓

(ii) Free float (FF) [**[3 Marks]** ✓

(iii) Independent Float (IND F) **[3 Marks]** ✓

(iv) Interfering Float (INT F) **[3 Marks]** ✓

Question Six [20 Marks]

1. Cross-Site Request Forgery (CSRF) is a web security vulnerability common according to Common Vulnerability Exposure.

(a) Describe CSRF using short notes **[4 Marks]**

(b) Explain briefly, how APIs as well as forms could be secured to prevent CSRF in a website **[2 Marks]**

(c) Discuss **four (4)** measures that could be put in place to mitigate CSRF by a website of a big organisation **[4 Marks]**

(d) Differentiate clear CSRF and XSS in terms of the following aspects;

(i) Attack goal **[2 Marks]**

(ii) Session requirement **[2 Marks]**

(iii) User interaction **[2 Marks]**

(iv) Attack vector **[2 Marks]**

(v) Data access **[2 Marks]**

CamScanner

Question Seven [20 Marks]

1. Common Vulnerability Exposure (CVE) is a publicly available catalog and reference system that identifies and standardizes known cybersecurity vulnerabilities and exposures in both software and hardware managed by MITRE cooperation.
   (a) Discuss the difference between Common Vulnerability Exposure (CVE) and Common Weakness Enumeration (CWE) **[2 Marks]**

   (b) Explain how, as a security professional, you would use CVE in vulnerability assessment and penetration testing in your organisation **[2 Marks]**

   (c) Briefly explain, how CVE contribute to prioritizing patch management in your organisation. **[2 Marks]**

   (d) A recent CVE describes a remote code execution vulnerability in a widely used server software. Describe steps you would take as a professional in an organisation to mitigate the risk posed by this CVE **[3 Marks]**

2. Describe the role of Common Vulnerability Scoring System (CVSS) in relation to CVEs **[4 Marks]**

3. Explain how CVSS base, temporal, and environmental scores help in vulnerability prioritization **[3 Marks]**

4. Explain briefly, what each colour code below means in CVSS;
   (a) Red **[1 Mark]**

   (b) Orange **[1 Mark]**

   (c) Green **[1 Mark]**

   (d) Yellow **[1 Mark]**

Q1 = 40

Q2 = 16

Q4 = 12

Q5 = 20

88%

CHECK YOUR WORK BEFORE SUBMISSION!

CamScanner